

TLP:CLEAR

Telegram Username-Buyout Pretext: From Cold DM to a Fake Fragment Mini App

Revision 1.1 — the delivery stage has now been observed, and it ends in a wallet drainer rather than a session hijack

Social Engineering | Telegram Mini App | TON Connect | Crypto Theft

Parameter	Value
Contact dates	August 20-21, 2026
Revision	1.1 — August 21, 2026 (supersedes 1.0 of August 20)
Classification	TLP:CLEAR
Type	Social Engineering -> Phishing via Telegram Mini App (crypto asset theft)
Threat level	MEDIUM
Targets	Two security researchers with public Telegram identifiers
Personas observed	3 (two "buyers", one posing as a platform notifier) + 1 inline bot
Compromise	Not confirmed for either target

Revision note

Revision 1.0 of this report, published on August 20, 2026, described a single cold contact and reconstructed the rest of the attack chain from external sources, stating explicitly that the downstream stage had not been observed. That reconstruction said the chain ends in a Telegram session hijack via a QR code or an SMS code, with the loss being the account itself.

On August 21 a second target received the same pretext and, sixteen minutes later, the stage that had previously been missing: a message impersonating a Fragment transaction notification, carrying a button that opens a Telegram Mini App. The Mini App link matches a publicly documented Fragment-impersonation phishing kit whose endgame is a TON Connect wallet drainer, not a session hijack.

This revision therefore corrects the central claim of revision 1.0: for this campaign, the asset primarily at risk is the victim's cryptocurrency wallet, not their Telegram account. Account takeover remains a possible variant of the same kit, but it is no longer the leading assumption. Readers who acted on revision 1.0 should re-read section 5.

1. Summary

Over 27 hours on August 20-21, 2026, two security researchers with public Telegram identifiers each received an unsolicited offer to buy their Telegram username. The two approaches came from different accounts and were worded differently, but followed one pattern: a cold direct message proposing a deal around Fragment, Telegram's official username marketplace, conducted through private chat rather than through the marketplace itself.

The first target declined and the contact stopped there. With the second target, the operation continued: sixteen minutes after the opening message, a third persona delivered a counterfeit platform notification with a confirmation button leading to a Telegram Mini App. No reply from the target was required for that escalation, which indicates an automated pipeline rather than an operator working by hand.

We are publishing this because the delivery stage marks a shift worth flagging: the lure has moved off the web and into Telegram itself. There is no domain, no address bar and no TLS certificate for a target to inspect, and nothing for defenders to block or submit for takedown.

2. Timeline

Time (UTC)	Stage	What happened
Aug 20, 08:56	Approach, target 1	Cold DM from @BlockRider454 offering to buy the target's username. No price, no marketplace reference. Target declined; no further contact.
Aug 21, 11:30	Approach, target 2	Cold DM from a persona with display name "NightVelocity" and no username: "I'm offering a deal on the Fragment website. The starting price is 5400 TON. I'm

		open to your offer."
Aug 21, 11:46	Delivery, target 2	A third persona, display name "Alert", sends a counterfeit "Fragment Official Transaction Notification" through the inline bot @trinformbot, with a "Confirm" button opening a Telegram Mini App.
Aug 21, 11:50	Reporting	Target 2 forwards both messages for analysis.

The interval between the opening message and the payload was 15 minutes 58 seconds.

3. The delivery stage

The counterfeit notification is formatted as a platform message: asset ("Telegram Username", "Collectible Username"), conversion type ("Username to NFT Asset"), blockchain ("TON"), an offer amount, a 5% platform service fee, and a status of "Pending Seller Confirmation". It closes with an escrow claim and a statement that confirmation is irreversible. A single inline button, "Confirm", opens a Mini App with a per-victim payload of the form <username>_<amount>_<fee>_Doc4.

Eight characteristics identify it as counterfeit, and they are worth teaching as a checklist because most of them are visible without any technical analysis:

- The message carries a visible "via @trinformbot" label. Telegram delivers system notifications only from the built-in Telegram account (ID 777000), and Fragment is a website that does not send direct messages at all.
- The currency is wrong, and it contradicts the operation's own opening message. The DM quoted 5400 TON; the "official notification" quotes 5400 GRAM. GRAM is the name of a token that was never launched and was abandoned in 2020; Fragment settles in TON. The two stages were evidently assembled from different templates.
- The "escrow mechanism" and the "Platform Service Fee (5%)" do not exist on Fragment. The fee line is groundwork for an advance-fee demand.
- The notifier persona displays a blue badge beside its name. This is almost certainly a Telegram Premium emoji status imitating verification; a genuine verification badge does not open anything when tapped.
- That persona is named "Alert" and has forwarding privacy enabled — built to look like a system notifier and to resist attribution.
- The button opens a Mini App inside Telegram rather than a website. There is no address bar, no certificate and no domain to verify.
- The payload is parameterised per victim, which indicates a templated pipeline rather than hand-crafted targeting.
- The text leans on irreversibility and urgency: "permanently converted", "irreversible and cannot be canceled", "Seller confirmation is required to release the funds".

4. Where the chain actually ends

The Mini App link matches the structure of a publicly documented phishing kit that impersonates Fragment inside Telegram Mini Apps. Public write-ups record sibling bots using links of the form `t[.]me/<bot>/start?startapp=<username>_price_<amount>` — the same technique of embedding the victim's handle and the offered sum in the deep link so the Mini App can render a personalised screen.

In the documented cases the Mini App presents an interface styled after Fragment and invites the victim to connect a TON wallet through TON Connect. Signing the connection request, and then a transaction, lets the operator move TON, jettons and NFTs out of the wallet. One analysed instance hosted its TON Connect manifest on GitHub and served the phishing front end from a throwaway .click domain; tooling of this class is sold ready-made.

We did not open the Mini App. The link is parameterised with the victim's handle, so opening it — or submitting it to a public URL scanner — would confirm to the operator that the target is being worked and would expose the analyst's own Telegram identity through the Mini App's init data. The identification above therefore rests on the link structure, the lure and the branding, not on a detonated sample.

5. Corrected risk chain

Revision 1.0 modelled the loss as: username, then session, then impersonation. The observed payload points elsewhere. The corrected chain, with the actions that matter at each step:

If the target...	Consequence	What to do
Ignores the message	None	Block and report the accounts
Opens the Mini App but connects nothing	The operator learns the target is live and receives their Telegram ID and name via Mini App init data	No financial action needed; block and report
Connects a wallet via TON Connect	No funds move on connection alone, but the app now holds an approved session	Revoke the connection immediately in the wallet's connected-apps settings
Signs any transaction	TON, jettons and NFTs can be moved out	Treat the wallet as compromised: move remaining assets to a wallet with a fresh seed phrase
Enters a seed phrase	The wallet is lost outright	TON Connect never asks for a seed phrase. Migrate everything immediately
Converts the username to an NFT to "complete the deal"	The handle becomes a transferable asset, irreversibly	Do not perform this step; it is the one action the victim takes on the genuine site

6. Why public identifiers remain a special case

The financial framing above does not cancel the reputational exposure described in revision 1.0. The same kit can be configured to take the account rather than the wallet, and for someone who uses Telegram as a working channel with sources, journalists and NGOs, that variant is the more damaging one.

- The real loss is trust in the identifier. Whoever controls the account can message sources and partner organisations while posing as the owner.
- Access to chat history is access to sources: it can deanonymise contacts and expose collection methods.
- A published username is already a target list; no reconnaissance is required to find it.

- A campaign can be entirely untargeted and still cause disproportionate harm when it lands on a visible account.

7. Indicators

Type	Value
Telegram username	@BlockRider454
Telegram display name	BlockRider
Telegram bio	Collector of usernames
Telegram display name	NightVelocity
Telegram user ID	8576276249
Telegram display name	Alert
Telegram bot	@trinformbot
Telegram bot ID	8986655554
Telegram bot display name	Trades
Mini App link (template)	hxxps://[.]me/trinformbot/start? startapp=<username>_<amount>_<fee>_Doc4
SHA-256 (bot avatar)	c306dddfcbc88af28435a826a70310f82faf7d281fa1 8ebf4e931b8fcacafe1e

Usernames and display names are the least stable of these: Telegram allows handles to be changed and recycled. Numeric user IDs survive that rotation and are the durable pivot. Note that only one of the three personas exposed its ID — the other two had forwarding privacy enabled — which is itself a useful observation: the operator's account pool is not configured consistently.

All three personas changed their display name and profile photo within a single window in June 2026, roughly two months before the campaign. This points to a pool of aged accounts repurposed for the operation rather than accounts registered for it.

Two further bot handles, @FragmentOffersRoBot and @SendingOffersBot, appear in third-party write-ups of the same kit. They are reproduced here as context, not as our own observation.

8. MITRE ATT&CK

ID	Technique
T1585.001	Establish Accounts: Social Media Accounts — a pool of personas repurposed for the campaign
T1656	Impersonation — a counterfeit Fragment platform notification and an imitated verification badge
T1598.003	Phishing for Information: Spearphishing via Service — cold outreach by Telegram DM

T1566.003	Phishing: Spearphishing via Service — payload delivered as an inline-bot message with a link button
T1204.001	User Execution: Malicious Link — the victim must open the Mini App
T1657	Financial Theft — wallet drain through TON Connect once a transaction is signed

9. Recommendations

9.1. If you have received this

- Do not press the confirmation button, and do not open the Mini App out of curiosity — the link identifies you to the operator.
- Never connect a wallet or sign a transaction from a link that arrived in a direct message. No seed phrase should ever be typed into a Mini App; TON Connect does not ask for one.
- If you connected a wallet, revoke the connection in your wallet's connected-apps settings. If you signed anything, move your assets to a wallet with a new seed phrase.
- Do not convert your username into an NFT to "complete" a deal proposed in chat.
- Block and report both the sender and the bot.

9.2. Standing hygiene

- Treat any Telegram message claiming to be a platform notification as counterfeit if it carries a "via @bot" label or a button. Genuine notifications come only from the Telegram account (ID 777000).
- Sell a username only through Fragment. A genuine buyer has no reason to negotiate privately.
- Enable Two-Step Verification with a cloud password; do not rely on SMS alone.
- Review Active Sessions periodically, and terminate all other sessions on any unexpected login code.
- Hide your phone number and restrict calls and group additions to contacts only.
- Keep a separate recovery channel: email with 2FA or a passkey, not just a phone number.

9.3. For organisations and contact networks

- Agree in advance on a fallback way to verify identity — a code word or a second channel. Set this up before an incident, not after.
- Verify any unusual message from a known contact through a different channel, especially if it asks for money, a link, or data.

10. Sources

- p05h, "Sophisticated Telegram Based Scam Designed to Fool Fragment Users," Medium, 2024-11
- "The Telegram Username Scam: How People Are Losing Thousands in TON," LearnHub / DEV Community, 2025-07
- DecentParadox, "Telegram Fragment Scam" — startapp link template used by sibling bots
- ton-blockchain/ton-connect, issue #104, "phishing page leads to drainer with ton connect link"
- "Telegram Mini Apps Abused in FEMITBOT Crypto Scam," Malaysian Wireless, 2026-05
- Authors' own observations, August 20-21, 2026

TLP:CLEAR — This document may be distributed without restriction.